Unit 3 WIKI: Introduction to Threat Modelling and Management

Abinel Madzivire

1. Introduction

Threat modelling is a systematic and proactive cybersecurity approach used to identify, analyse, prioritise and mitigate potential threats to information systems, applications and network infrastructure. It enables organisations to anticipate possible attacks and implement appropriate security controls before vulnerabilities are exploited.

According to the Open Worldwide Application Security Project (OWASP, n.d.), threat modelling involves understanding system architecture, identifying potential security threats, determining appropriate mitigations and reviewing their effectiveness.

Effective threat modelling contributes to the confidentiality, integrity and availability (CIA) of information systems while supporting organisational risk management and informed security decision-making.

2. Understanding the Difference Between Threats and Vulnerabilities

Although the terms *threat* and *vulnerability* are closely related, they represent different cybersecurity concepts.

Threat: A potential event, actor or circumstance capable of causing harm to an information system or organisational asset. Examples include ransomware attacks, phishing, insider threats and distributed denial-of-service (DDoS) attacks.

Vulnerability: A weakness within software, hardware, network architecture, security controls or organisational procedures that could be exploited by a threat actor.

Risk: The potential adverse consequences arising when a threat exploits a vulnerability, considered in terms of likelihood and impact.

For example, within a fibre-to-the-premises (FTTP) network:

- **Threat:** An unauthorised individual attempting to intercept customer communications.
- **Vulnerability:** Inadequate authentication or insecure management interfaces on network equipment.
- **Risk:** Unauthorised access, disclosure of customer information or disruption of network services.
- **Mitigation:** Strong authentication, secure configuration, encryption, network segmentation and continuous monitoring.

This distinction is particularly important because identifying a vulnerability does not automatically establish that exploitation is likely or that the resulting business impact will be significant.

3. Common Threat Modelling Techniques

3.1 STRIDE Threat Modelling Framework

STRIDE is a threat identification methodology developed by Microsoft. It categorises security threats into six distinct groups (Microsoft, n.d.).

Category	Description	Example
Spoofing	Impersonating an authorised identity	Using stolen administrator credentials
Tampering	Unauthorised modification of data	Altering network configurations
Repudiation	Denying actions without reliable evidence to establish accountability	Deleting or manipulating audit logs
Information Disclosure	Unauthorised exposure of sensitive information	Intercepting customer data
Denial of Service	Disrupting legitimate access to services	Flooding a network gateway with traffic
Elevation of Privilege	Obtaining permissions beyond those authorised	Exploiting a flaw to gain administrator access

Strengths: STRIDE provides a structured framework that supports systematic threat identification. It is particularly suitable for applications, network infrastructure and systems represented through data flow diagrams.

Limitations: STRIDE does not independently establish threat likelihood or business impact. Consequently, additional risk assessment techniques are necessary to prioritise identified threats.

3.2 DREAD Risk Assessment Model

DREAD is a threat assessment approach traditionally associated with Microsoft security practices. It evaluates identified threats using five criteria:

1. **Damage Potential:** The severity of the consequences if exploitation succeeds.
2. **Reproducibility:** The ease with which an attack can be repeated.
3. **Exploitability:** The effort and technical expertise required to exploit the vulnerability.

4. **Affected Users:** The number or proportion of users potentially affected.
5. **Discoverability:** The likelihood that attackers can identify the weakness.

The traditional approach assigns each criterion a score between 1 and 10 and calculates an average.

For example, a hypothetical threat with scores of 8, 7, 6, 9 and 5 would receive:

DREAD Score = (8 + 7 + 6 + 9 + 5) / 5 = **7.0/10**

However, the model has limitations because scoring relies heavily on subjective judgement. Different assessors may assign significantly different scores to identical threats.

Therefore, DREAD should not be treated as an objective measurement of risk, but rather as a preliminary prioritisation tool supported by contextual evidence and organisational risk criteria.

3.3 Attack Trees

Attack trees provide a graphical representation of the different methods an attacker could use to achieve a particular malicious objective.

The primary attack objective is represented as the root node, while branches illustrate alternative or combined attack pathways.

For example, an attack tree targeting an FTTP network might have the objective:

Gain unauthorised administrative access to a customer router.

Potential pathways could include:

- Compromising administrative credentials through phishing.
- Exploiting an unpatched router management interface.
- Abusing weak remote-management authentication.
- Obtaining access through an incorrectly configured support account.

Attack trees are particularly effective for understanding multi-stage attacks and identifying security controls capable of interrupting several attack pathways.

However, complex systems may generate extensive attack trees that require regular maintenance.

3.4 Process for Attack Simulation and Threat Analysis (PASTA)

PASTA is a risk-centred threat modelling methodology that combines business objectives, technical analysis and potential attack scenarios.

It comprises seven stages:

1. Define business objectives.
2. Define the technical scope.
3. Decompose the application or system.
4. Analyse potential threats.
5. Identify vulnerabilities and weaknesses.
6. Model potential attacks.
7. Analyse risks and recommend countermeasures.

Unlike STRIDE, which primarily supports structured threat identification, PASTA places greater emphasis on business impact and realistic attack scenarios.

Strengths: It supports detailed, risk-informed security decisions and aligns technical threats with organisational objectives.

Limitations: PASTA can be resource-intensive because it requires considerable technical expertise, system knowledge and collaboration between business and security stakeholders.

It is therefore particularly appropriate for complex systems, high-value assets and organisations requiring comprehensive security assessments.

4. Selecting an Appropriate Threat Modelling Technique

The choice of methodology should depend on the organisation's security objectives, system complexity, available resources and risk exposure.

Situation	Recommended technique	Justification
Developing a new web application	STRIDE	Systematic identification of design-level security threats
Prioritising previously identified threats	DREAD, supported by contextual risk assessment	Provides a preliminary comparative assessment
Investigating a specific attacker objective	Attack Trees	Illustrates possible attack pathways
Assessing a complex financial platform	PASTA	Connects technical threats with business impact
Assessing a telecommunications network	STRIDE combined with Attack Trees and risk assessment	Addresses architecture, attack pathways and operational risk

No single methodology is universally suitable. OWASP (n.d.) emphasises the importance of selecting an approach that reflects the particular system and security objectives.

5. Hybrid Threat Modelling Approaches

Hybrid threat modelling combines complementary methodologies to provide a more comprehensive understanding of cybersecurity risks.

For example, an organisation managing FTTP infrastructure could adopt the following approach:

Stage 1 – STRIDE: Identify possible threats affecting customer routers, optical network terminals, authentication mechanisms and management platforms.

Stage 2 – Attack Trees: Examine how an attacker might compromise network equipment or gain unauthorised administrative access.

Stage 3 – Risk Assessment: Evaluate the likelihood, potential business impact and effectiveness of existing controls. DREAD may support initial comparisons, but should not be the sole risk measure.

Stage 4 – PASTA: Align the technical analysis with organisational objectives such as customer privacy, network availability, regulatory compliance and service continuity.

Combining these techniques enables organisations to move beyond simply identifying threats towards understanding how attacks could occur, assessing their consequences and implementing proportionate controls.

However, hybrid approaches should be selected carefully because combining multiple frameworks can increase complexity, duplication and assessment costs.

6. Practical Application: Threat Modelling in FTTP Telecommunications

In FTTP infrastructure, threat modelling can help organisations assess security risks associated with customer premises equipment, access networks, network management systems and remote maintenance activities.

Consider a scenario where an attacker attempts to compromise a remotely managed optical network terminal (ONT).

Using STRIDE, the organisation could identify:

- **Spoofing:** Impersonation of authorised maintenance personnel.
- **Tampering:** Unauthorised modification of ONT configurations.
- **Information Disclosure:** Exposure of customer network information.
- **Denial of Service:** Disruption of broadband connectivity.

- **Elevation of Privilege:** Exploitation of management interfaces to obtain higher permissions.
- **Repudiation:** Inadequate logging that prevents reliable attribution of configuration changes.

Appropriate mitigations may include strong authentication, role-based access control, secure remote-management protocols, firmware updates, monitoring and centralised security logging.

This example demonstrates the value of incorporating threat modelling into network deployment, maintenance and continuous security improvement.

7. Critical Reflection

In my view, effective threat modelling requires both technical analysis and an understanding of organisational risk. Although STRIDE is useful for identifying different categories of threats, it cannot independently determine which threats deserve immediate attention.

Similarly, DREAD offers a structured scoring mechanism but remains susceptible to subjectivity. Attack Trees provide valuable insight into attacker behaviour, while PASTA supports closer alignment between cybersecurity and business objectives.

I therefore consider hybrid threat modelling particularly useful for telecommunications environments, where network availability, customer confidentiality, infrastructure integrity and operational continuity are closely interconnected.

Nevertheless, additional frameworks should only be introduced where they contribute meaningful analytical value.

Ultimately, threat modelling should be treated as a continuous security management activity rather than a one-off exercise. Regular reviews are necessary because system architectures, vulnerabilities, attacker capabilities and organisational priorities change over time.

8. Conclusion

Threat modelling is an essential component of proactive cybersecurity risk management. STRIDE, DREAD, Attack Trees and PASTA each contribute different capabilities to identifying, analysing and managing security threats.

The most appropriate methodology depends on the system under consideration, the organisation's objectives and available resources. Combining complementary techniques can improve the quality of security decisions, provided their additional complexity is justified.

For telecommunications systems in particular, integrating architectural threat identification, attack pathway analysis and business-focused risk assessment can strengthen organisational resilience against evolving cyber threats.

References

Microsoft (n.d.) *Secure by design*. Available at: https://www.microsoft.com/en-us/securityengineering/sdl/practices/secure-by-design (Accessed: 8 October 2026).

Microsoft (n.d.) *Threat modeling for drivers*. Microsoft Learn. Available at: https://learn.microsoft.com/en-us/windows-hardware/drivers/driversecurity/threat-modeling-for-drivers (Accessed: 8 October 2026).

National Institute of Standards and Technology (NIST) (2016) *Guide to Data-Centric System Threat Modeling*. Draft Special Publication 800-154. Available at: https://csrc.nist.gov/pubs/sp/800/154/ipd (Accessed: 8 October 2026).

OWASP (n.d.) *Threat Modeling Cheat Sheet*. Available at: https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html (Accessed: 8 October 2026).

OWASP (n.d.) *Threat Modeling*. OWASP DevSecOps Guideline. Available at: https://owasp.github.io/DevSecOpsGuideline/2-Process/2-1-Design/2-1-1-Threat-modeling/ (Accessed: 8 October 2026).